# SIZMA TESTİ RAPORU

| | |
|---|---|
| **Rapor Tarihi** | 20/10/2026 |
| **Hazırlayan** | Ömer Faruk Baysal |
| **Test Hedefi** | PortSwigger Web Academy Lab |

## 1. Username enumeration

Bu raporda, PortSwigger Web Security Academy'de yer alan Username enumeration konusuyla ilgili iki farklı durum tek bir bulgu altında ele alınmıştır.

## 2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın giriş (login) mekanizmasının geçerli ve geçersiz kullanıcı adlarına farklı yanıtlar verdiği ve bu sayede sistemde kayıtlı kullanıcı adlarının yetkisiz biçimde tespit edilebildiği (username enumeration) gözlemlenmiştir. Zafiyetin iki farklı biçimde ortaya çıktığı görülmüştür: açıkça farklı bir hata mesajı döndürülmesi ve gözle ayırt edilemeyecek kadar küçük (yanıt uzunluğu düzeyindeki) farklar. Geçerli kullanıcı adlarının elde edilmesi, parola deneme (brute-force) saldırılarının önünü açtığından ve testte hedef hesaba tam erişimle sonuçlandığından, zafiyetin giderilmesi önerilmektedir.

## 3. Zafiyet Açıklaması

### Durum 1: Username enumeration via different responses

Hedef uygulamanın giriş formunda, geçersiz bir kullanıcı adı girildiğinde dönen hata mesajı ile geçerli bir kullanıcı adına yanlış parola girildiğinde dönen hata mesajının birbirinden farklı olduğu gözlemlenmiştir. Bu fark, bir saldırganın hangi kullanıcı adlarının sistemde kayıtlı olduğunu yanıtları karşılaştırarak ayırt etmesine olanak tanımaktadır.

### Durum 2: Username enumeration via subtly different responses

İlk durumdan farklı olarak, geçerli ve geçersiz kullanıcı adlarına dönen hata mesajları gözle bakıldığında aynı görünmektedir. Ancak yanıtlar incelendiğinde, geçerli bir kullanıcı adında yanıtın çok küçük bir biçimde (yanıt uzunluğu / mesajdaki ince bir fark düzeyinde) değiştiği tespit edilmiştir. Bu ince fark, mesaj aynı görünse dahi kullanıcı adının sayılabilmesine imkân vermektedir.

## 4. Risk Seviyesi

| | |
|---|---|
| **Risk Seviyesi** | Orta |
| **CVSS v3.1 Skoru** | 5.3 |
| **CVSS v3.1 Vektörü** | AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **CWE** | CWE-204 (Observable Response Discrepancy) |

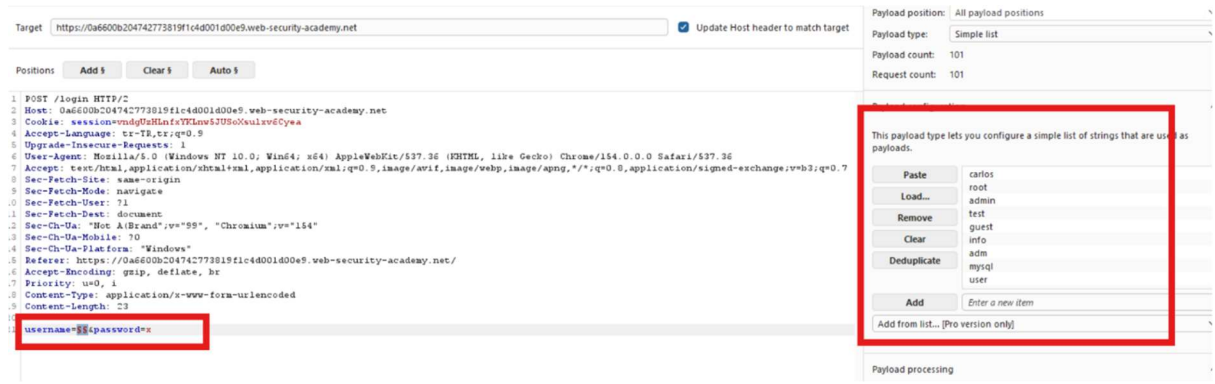
## 5. Etki

Yapılan testler sonucunda, kimliği doğrulanmamış bir saldırgan, giriş mekanizmasının yanıt farklarından yararlanarak sistemde kayıtlı geçerli kullanıcı adlarını tespit edebilmektedir. Doğrulanan etki, geçerli kullanıcı adlarının yetkisiz biçimde ifşa olmasıdır. Bu bilgi tek başına sınırlı bir gizlilik kaybı oluşturse da, parola deneme (brute-force) saldırılarının kapsamını daralttığı için saldırının başarısını ciddi biçimde artırır; nitekim bu testte, tespit edilen kullanıcı adı üzerinden parola denemeleriyle hedef hesaba tam erişim sağlanmıştır. Potansiyel etki, elde edilen geçerli kullanıcı adlarıyla sistem genelinde hesap ele geçirme ve kimlik avı (phishing) saldırılarının hedeflenmesidir.

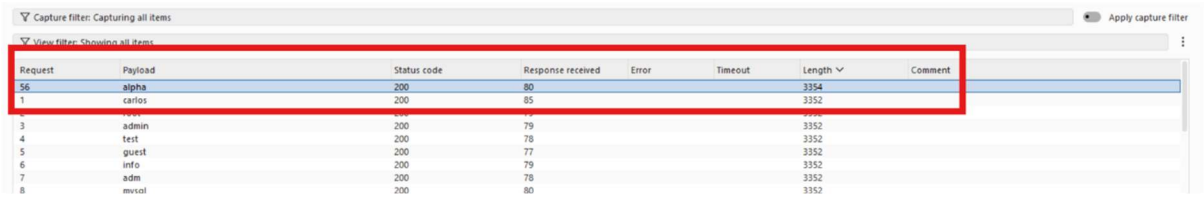
## 6. Proof Of Concept

### Durum 1: Username enumeration via different responses

Hedef uygulamada test edilmesi istenen giriş formunun ilgili post isteği Burp Intruder'a aktarılıp username ve password alanları, intruderda yer alan sniper attack kullanılarak sırayla test edilebilmektedir. Bu testler için test edilmesi istenen hazır 100 adet username ve 100 adet passwordden oluşan listeler kullanıldığında doğru username değerinin "alpha", password değerinin ise "123123" olduğu tespit edilmektedir.




*Şekil 1: Intruder'da sniper attack*



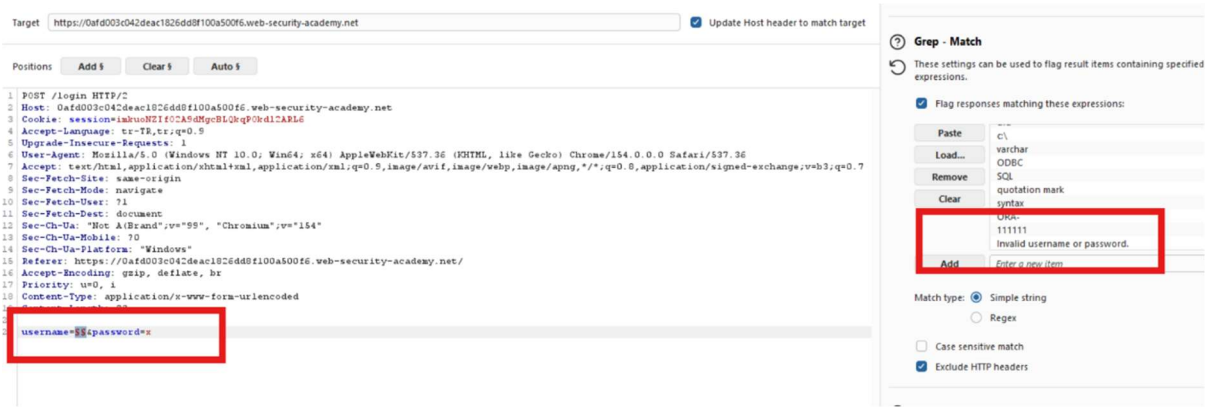

*Şekil 2: Username testi sonucunda lengthi farklı olan payload*

| Request | Payload | Status code | Response received | Error | Timeout | Length | Comment |
|---|---|---|---|---|---|---|---|
| 0 | | 400 | 81 | | | 141 | |
| 1 | 123456 | 200 | 81 | | | 3354 | |
| 2 | password | 200 | 80 | | | 3354 | |
| 3 | 12345678 | 200 | 78 | | | 3354 | |
| 4 | qwerty | 200 | 79 | | | 3354 | |
| 5 | 123456789 | 200 | 81 | | | 3354 | |
| 6 | 12345 | 200 | 80 | | | 3354 | |
| 7 | 1234 | 200 | 81 | | | 3354 | |
| 8 | 111111 | 200 | 78 | | | 3354 | |
| 9 | 1234567 | 200 | 80 | | | 3354 | |
| 10 | dragon | 200 | 79 | | | 3354 | |
| 11 | 123123 | 302 | 121 | | | 187 | |
| 12 | baseball | 200 | 120 | | | 3441 | |
| 13 | abc123 | 200 | 80 | | | 3441 | |
| 14 | football | 200 | 122 | | | 3441 | |
| 15 | monkey | 200 | 121 | | | 3441 | |
| 16 | letmein | 200 | 81 | | | 3441 | |
| 17 | shadow | 200 | 81 | | | 3441 | |

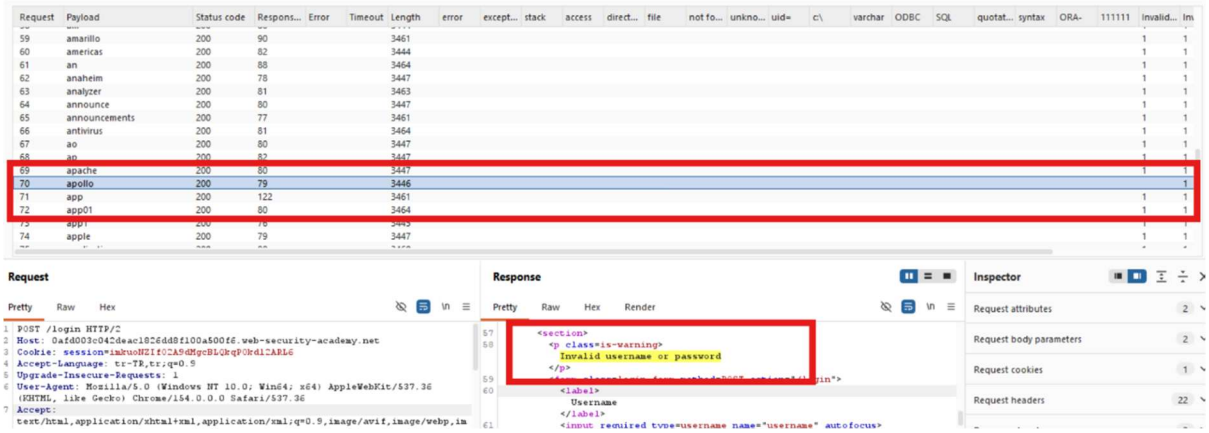
*Şekil 3: Password payload testi*

## Durum 2: Username enumeration via subtly different responses

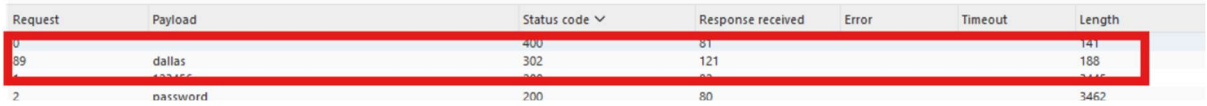
Hedef uygulamada test edilmesi istenen giriş formunun ilgili post isteği Burp Intruder'a aktarılıp username ve password alanları, intruderda yer alan sniper attack kullanılarak sırayla test edilebilmektedir. Bu testler için test edilmesi istenen hazır 100 adet username ve 100 adet passwordden oluşan listeler kullanıldığında lengthlerin biribirinden farklı geldiği tespit edilmektedir. Bu yüzden response'da dönen "Invalid username or password." cümlesi grep özelliğinde etkinleştirilerek test yapılması gerekmektedir. Böylelikle username için farklı gelen yanıt tespit edilebilmektedir.



*Şekil 4: Grep özelliğini kullanma*



*En sonda nokta yok. Username "apollo"*



Doğru isim tespit edildikten sonra şifre de bu isim kullanılarak payloadlar ile birlikte tespit edilebilmektedir.

## 7. Çözüm Önerisi

Giriş, kayıt ve parola sıfırlama gibi kimlik doğrulamayla ilgili tüm akışlarda, kullanıcının var olup olmadığını ele veren farklar ortadan kaldırılmalıdır. Kullanıcı adının ya da parolanın yanlış olduğu durumların tümünde tek tip ve genel bir hata mesajı (ör. “Kullanıcı adı veya parola hatalı”) döndürülmeli; mesaj metni, HTTP durum kodu ve yanıt gövdesi her durumda birbirinin aynısı olmalıdır. Yanıtlar arasında uzunluk ya da biçim düzeyinde ince farklar bırakılmamalıdır. Ayrıca geçerli ve geçersiz kullanıcılar için işlem süreleri eşitlenerek zamanlama tabanlı sayım engellenmeli ve denemeler, hesap sayımını ve brute-force’u sınırlayan oran sınırlama (rate limiting) ile birlikte korunmalıdır.

## 8. Sonuç

Yapılan testler sonucunda hedef uygulamanın giriş mekanizmasının, geçerli kullanıcı adlarını hem açık hata mesajı farkıyla hem de gözle ayırt edilemeyecek kadar küçük yanıt farklarıyla ele verdiği doğrulanmıştır. Zafiyet tek başına bir bilgi ifşası olmakla birlikte, parola deneme saldırılarıyla birleştiğinde hesap ele geçirmeye kadar ilerleyebilmektedir. Kimlik doğrulama akışlarında yanıtların tek tipleştirilmesi ve oran sınırlama uygulanarak zafiyetin giderilmesi önerilmektedir.